

KITOALL

A Unified Framework for Sovereign AI Governance

Research Paper — Public Release

Author	Ahmad Qasim Mohammad Hassan
ORCID	0009-0001-4360-0802

Abstract

This paper presents KITOALL, an architectural framework that addresses a critical gap in enterprise AI deployment: the absence of a unified governance layer that binds entity identity, governance decision, and communication security into a single inseparable system.

KITOALL comprises three pillars: USID (Unique Secure Identifier), IDS (Intelligent Decision System), and SCB (Secure Context Bridge) — backed by an audit log carrying mathematical guarantees against tampering.

Keywords: AI Governance, EU AI Act, Entity Identity, Cybersecurity.

1. The Problem

Existing commercial solutions (ChatGPT Enterprise, Gemini for Workspace, and others) transfer data to external servers and rely on commercial privacy policies — not on verifiable architectural guarantees. This is unacceptable because:

- EU AI Act mandates tracing every operation to the executing entity
- Prompt Injection threatens unprotected AI systems
- Loss of data control undermines institutional autonomy

2. Gap in Existing Research

Domain	Problem
UUID / W3C DID	Addresses humans or devices separately — does not unify all three (human + device + AI agent)
Kong / AWS Gateway	Applies network-level rules, not AI governance rules
ELK / Splunk	Records events but provides no mathematical guarantees against tampering

KITOALL closes the gap by unifying all three functions into a single inseparable system.

3. Architectural Framework

3.1 Pillar 1: USID — Unique Secure Identifier

A unified digital identity for every entity — human, device, or AI agent.

```
USID = { unique_id, entity_type, entity_state, cryptographic_hash }
entity_type: HUMAN | DEVICE | AI_AGENT
entity_state: ACTIVE | SUSPENDED | REVOKED
```

Innovation: No existing system unifies all three entity types into a single governable identity.

3.2 Pillar 2: IDS — Intelligent Decision System

The governance gateway through which every request passes before reaching an AI model.

```
IDS(request) → APPROVE | REJECT | ESCALATE
```

Rules applied automatically to every request:

Rule Code	Rule	Article
IDS-R-001	USID is mandatory	Article 13
IDS-R-002	Prompt Injection detection	Article 15
IDS-R-003	Audit logging is mandatory	Article 12
IDS-R-004	Suspended USID = immediate rejection	Article 14
IDS-R-005	Human escalation within ≤ 60 seconds	Article 14
IDS-R-006	Data placement decision (ON_THE_FLY / CONTINUOUS_LEARNING)	Article 10

3.3 Pillar 3: SCB — Secure Context Bridge

The sole authorized encrypted channel between KITOALL components. Every message is encapsulated in a ContextPacket carrying sender and receiver identity, a cryptographic content hash, and a digital signature. Any message that does not conform to this format is rejected immediately.

Production deployment: mTLS 1.3 with certificate pinning per component.

3.4 Audit Log

KITOALL employs a cryptographic chaining mechanism that ensures any tampering with any log record is detected mathematically and immediately — without an external witness or distributed network. This satisfies the requirements of Article 12 of the EU AI Act.

4. Comparison with Existing Solutions

Criterion	KITOALL	UUID+JWT	Kong	Blockchain
AI Agent identity	✓	✗	✗	✗
EU AI Act governance	✓	✗	✗	✗
Mathematical tamper-proof guarantee	✓	✗	✗	✓
Vendor-independent	✓	✓	✗	✓
No Blockchain required	✓	✓	✓	✗
Unified identity for all three types	✓	✗	✗	✗

5. Compliance with International Standards

EU AI Act (Regulation EU 2024/1689)

Article	Subject	Component
Article 9	Risk Management	IDS
Article 10	Data Governance	ON_THE_FLY / CONTINUOUS decision
Article 12	Logging	Audit Log
Article 13	Transparency	USID
Article 14	Human Oversight	IDS — escalation ≤ 60 seconds
Article 15	Cybersecurity	SCB + Prompt Injection detection

ISO/IEC 42001:2023

Clause	Subject	Component
Clause 6.1	Risk Management	IDS

NIST AI RMF (2023)

Function	Component
GOVERN / MAP / MEASURE / MANAGE	IDS + USID + Audit Log

6. Open and Commercial Editions

Open Edition (this repository)

Includes the three pillars (USID, IDS, SCB) as separate components available for study and extension.

KITOALL Enterprise

The detailed Implementation Specification — covering how the three pillars integrate with one another, including their binding mechanism, execution sequence, and the audit log with its mathematical guarantees — is available exclusively under the commercial license.

This specification enables institutional teams to build the full integration correctly, with guaranteed full compliance with the EU AI Act.

7. Conclusion

The innovation in KITOALL is not in its individual components — UUID, API gateways, and mTLS already exist. What is new is their integration into a single indivisible system that automatically enforces EU AI Act requirements on every request, with a unified identity for the human, the device, and the AI agent.

References

[1] European Commission, “Regulation EU 2024/1689 (EU AI Act)”, 2024.
[2] ISO/IEC 42001:2023, “AI Management System”.
[3] NIST, “AI Risk Management Framework (AI RMF 1.0)”, 2023.
[4] Leach et al., “RFC 4122: UUID URN Namespace”, IETF, 2005.
[5] W3C, “Decentralized Identifiers (DIDs) v1.0”, 2022.
[6] OWASP, “Top 10 for Large Language Model Applications”, 2023.
[7] Amodei et al., “Concrete Problems in AI Safety”, arXiv:1606.06565, 2016.

Intellectual Priority Declaration

This paper constitutes documented intellectual priority as of the publication date. No entity may register a patent on the following concepts:

- The triadic integration USID + IDS + SCB as a unified governance layer
- Unified identity for human, device, and AI agent in AI governance
- Automatic application of EU AI Act + ISO 42001 + NIST AI RMF in a single layer
- Data placement decision (ON_THE_FLY / CONTINUOUS_LEARNING) at the governance gateway level

© 2025-2026 Ahmad Qasim Mohammad Hassan

ORCID: 0009-0001-4360-0802

